QAYRAWAN INFORMATION SYSTEMS

Company Profile and Scope

ECC Compliance Program · Document 1 of the QIS case study

Document ID	QIS-PRF-001
Version	0.1 (Draft)
Date	24 October 2026
Classification	Internal
Prepared by	Naif Alsalem, GRC Lead

Fictional case study. Qayrawan Information Systems (QIS), its people and its clients are invented for a professional portfolio. Any resemblance to a real organization is unintended. The regulators and frameworks named are real.

Document control

Role	Name	Status
Prepared by	Naif Alsalem, GRC Lead	Complete
Reviewed by	Reem Al-Otaibi, Chief Technology Officer	Pending
Approved by	Faisal Al-Harbi, Chief Executive Officer	Pending

Version history

Version	Date	Author	Change
0.1	24 Oct 2026	Naif Alsalem	First draft for review

Review cycle: annually, or sooner when QIS's services, clients or applicable regulations change.

1. Purpose

This document defines who QIS is, what it does, and what its ECC compliance program covers. It is the reference point for every later document in the program.

- The asset inventory and data classification draw their assets from sections 3, 4 and 6.
- The risk register and ECC gap assessment work within the scope set in section 9.
- The risk treatment plan and policies answer to the objectives in section 8.

It describes QIS as it stands when the program begins. It records facts, not findings. Weaknesses are identified and assessed in the documents that follow.

2. Company overview and history

QIS is a privately owned Saudi IT services company with about 250 staff. It is headquartered in Riyadh, has an office in Jeddah, and serves six government clients.

The name comes from qayrawan (قيروان), the classical Arabic word for a caravan or the camp where it halts. Connecting people and systems is the company's business.

QIS grew slowly from 2011 to 2016, then quickly as government digitization accelerated. Its security practices did not grow at the same pace. The regional events below shaped the rules QIS must now meet.

Year	Event
2011	Faisal Al-Harbi founds QIS in Riyadh, offering network installation and helpdesk support to private companies.
2012	The Shamoon malware attack on Saudi Aramco wipes about 30,000 workstations and makes cybersecurity a national priority. QIS, then a small firm, makes no changes.
2014	QIS wins its first government contract, maintaining a legacy application for Client F.
2016	Saudi Vision 2030 is launched. Government digitization drives rapid growth in QIS's government work.
2017	The National Cybersecurity Authority (NCA) is established.

Year	Event
2018	NCA publishes the Essential Cybersecurity Controls (ECC-1:2018). QIS begins managed IT services for Client B.
2019	QIS opens its Jeddah office.
2021	QIS launches Client A's citizen portal and begins hosting client systems with a Saudi cloud provider.
2023	The Personal Data Protection Law (PDPL) enters into force.
2024	NCA publishes the updated controls, ECC-2:2024.
2026	Client A's contract renewal requires QIS to demonstrate ECC compliance. QIS hires its first GRC Lead.

3. Services

QIS delivers three service lines. Each one connects QIS to client systems or client data in a different way.

Service line	What QIS does	Clients
Managed IT services	Helpdesk support, endpoint management and network monitoring for client staff. Technicians connect to client networks remotely.	A, B, C, E
Application hosting	Hosts and operates client systems on a cloud platform run by a CST-licensed provider inside the Kingdom.	A, C, D
Software development and maintenance	Builds, maintains and updates client applications, including Client A's citizen portal and Client F's legacy application.	A, F

4. Clients

QIS serves six government entities. They are identified by label only, following standard practice for protecting client identity.

Client	Type	What QIS does for them	Data QIS handles	Tier
Client A	Ministry	Built and hosts its citizen portal, and provides helpdesk support. Contract up for renewal.	Citizens' personal data	Critical
Client B	Regulatory authority	Full managed IT: endpoint management for about 400 staff devices, plus remote support.	Internal records, some confidential	High
Client C	Public university	Helpdesk support, and hosting for its student services system.	Student records	High
Client D	Municipality	Hosts and maintains its permit application system.	Applicant and property data	Medium
Client E	Government agency	Network monitoring and remote support.	Network configurations	Medium
Client F	Small authority	Maintains a legacy application. Contract ends in 2027.	Limited internal data	Low

Tier reflects the sensitivity of the data QIS handles and the depth of its access, in that order.

5. Organization and governance

QIS is led by its founder and CEO, with three executives reporting to him. Cybersecurity sits inside the technology organization and reports to the CTO. The new GRC Lead joins the same reporting line.

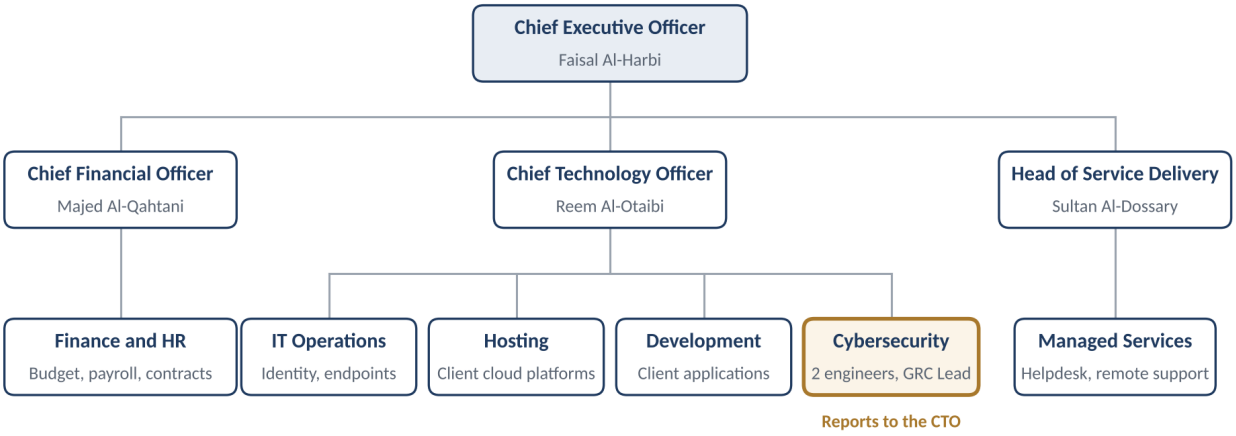


Figure 1. QIS organization, October 2026

Leadership and program roles

Name	Role	Responsibilities	Role in the program
Faisal Al-Harbi	Chief Executive Officer	Founder. Overall accountability for QIS.	Program sponsor. Approves policies and risk acceptance.
Reem Al-Otaibi	Chief Technology Officer	IT operations, hosting, development and security.	Owns most technical risks and controls.
Majed Al-Qahtani	Chief Financial Officer	Finance, HR and contracts.	Approves the program budget. Owns HR-related controls such as screening and leavers.
Sultan Al-Dossary	Head of Service Delivery	Managed services, client technicians and client relationships.	Owns client access and client-facing commitments.
Naif Alsalem	GRC Lead (joined October 2026)	Governance, risk and compliance.	Program owner. Author of the program documents.

Headcount by function

Function	Staff
Managed services (helpdesk and remote support)	120
Development	45
IT operations and hosting	40
Finance, HR and administration	30
Leadership and business development	12
Cybersecurity (2 engineers, 1 GRC Lead)	3

Function	Staff
Total	250

6. Technology environment

The environment below is described as QIS's IT team reports it. It is the starting point for the asset inventory.

Area	What QIS runs
Identity	On-premises Active Directory set up in 2011, synchronized to Microsoft Entra ID for Microsoft 365 email and files.
Endpoints	About 300 Windows laptops. Some staff read work email on personal phones.
Headquarters server room	A legacy file server, an older finance and HR system, and a backup storage device.
Client hosting	Client systems hosted with a CST-licensed Saudi cloud provider.
Client access	A remote management tool, plus VPN accounts for each client network. Some technicians share accounts.
Development	Code repositories and a build pipeline for Client A's citizen portal.
Jeddah office	Connected to headquarters over a site-to-site VPN.
Security tools	Firewalls and antivirus. No central logging or monitoring. Multi-factor authentication is not used on every system.

7. Regulatory context

QIS is not itself a government entity, but it is bound by ECC through its government clients. Each client must apply ECC's third-party cybersecurity requirements to its service providers. Other regulations apply because of the data QIS handles and where it hosts it.

Regulator	Instrument	Why it applies to QIS
National Cybersecurity Authority (NCA)	Essential Cybersecurity Controls, ECC-2:2024	QIS's government clients must apply ECC to their service providers. Client A's renewal requires QIS to demonstrate compliance.
National Cybersecurity Authority (NCA)	Cloud Cybersecurity Controls (CCC)	QIS hosts government systems in the cloud.
Communications, Space and Technology Commission (CST)	Cloud computing regulatory framework	QIS hosts client systems with a licensed cloud provider inside the Kingdom.
Saudi Data and AI Authority (SDAIA)	Personal Data Protection Law (PDPL)	Client A's citizen portal and Client C's student system process personal data.
National Data Management Office (NDMO, part of SDAIA)	National data management, classification and personal data protection standards	QIS handles government data that clients classify under these standards.

> **Verification note.** These references reflect the author's working knowledge as of October 2026. Confirm each

> instrument's current version on the NCA, CST and SDAIA websites before this document is approved.

8. Program trigger and objectives

Client A's contract expires on 30 April 2027. Its renewal requires QIS to demonstrate compliance with ECC-2:2024 as Client A's service provider. That gives the program six months.

#	Objective	Evidence of success	Target
1	Establish an independent cybersecurity function	Function reports to the CEO. Cybersecurity charter approved.	Dec 2026
2	Identify and classify assets	Asset inventory and data classification approved.	Nov 2026
3	Assess cybersecurity risk	Risk methodology and risk register approved by the CEO.	Dec 2026
4	Measure ECC compliance	Gap assessment complete for every applicable ECC control.	Dec 2026
5	Treat priority risks	Treatment plan funded. Critical and high actions on schedule.	Mar 2027
6	Set governance	Core cybersecurity policies approved and communicated to staff.	Feb 2027
7	Demonstrate compliance	Evidence pack accepted by Client A.	Apr 2027

Program governance

- **Sponsor:** Faisal Al-Harbi, CEO
- **Owner:** Naif Alsalem, GRC Lead
- **Steering committee:** CEO, CTO, CFO, Head of Service Delivery and GRC Lead. Meets monthly to review progress, approve decisions and accept risks.

9. Scope

In scope

- All three service lines: managed IT services, application hosting, and software development and maintenance.
- Riyadh headquarters and the Jeddah office.
- Corporate IT: identity, email and files, endpoints, the headquarters server room, and the finance and HR system.
- Systems QIS hosts, builds or manages for Clients A to F.
- All QIS staff and contractors.
- Third parties QIS depends on, including its cloud provider and software vendors.

Out of scope

Area	Reason
Clients' own systems and networks beyond QIS's managed services	Each client is responsible for its own environment.

Area	Reason
The cloud provider's internal infrastructure	Covered by the provider's own compliance and attestations under the shared responsibility model.
Physical security of client premises	Controlled by each client.

Assumptions and constraints

- **Deadline:** six months until Client A's renewal on 30 April 2027.
- **Capacity:** the security team is two engineers. The GRC Lead is the only governance resource.
- **Budget:** not yet set. The CFO will approve funding once risks are assessed.
- **Evidence:** with no central logging, some compliance evidence must be gathered by hand.
- **Sponsorship:** the CEO's sponsorship continues for the length of the program.

10. Related documents

The program produces the documents below, in this order. Each one draws on the documents before it.

ID	Document	Program phase
QIS-PRF-001	Company Profile and Scope (this document)	1. Context
QIS-AST-001	Asset Inventory	2. Identify
QIS-DCL-001	Data Classification	2. Identify
QIS-RMM-001	Risk Management Methodology	3. Assess
QIS-RR-001	Risk Register	3. Assess
QIS-GAP-001	ECC Gap Assessment	3. Assess
QIS-RTP-001	Risk Treatment Plan	4. Treat
QIS-POL-001 onward	Cybersecurity policies	5. Govern
QIS-IRP-001	Incident Response Plan	6. Operate
QIS-IAR-001	Internal Audit Report	6. Operate

Appendix A. Open items for version 0.2

These points need a decision before the next version.

#	Open item	Proposed default
1	Program budget: set a figure now, or decide after the risk assessment?	Decide after the risk assessment, as section 9 states.
2	How many contractors work for QIS, and in which functions?	About 20, mostly developers.
3	Does the Jeddah office hold any servers or network equipment beyond laptops?	Laptops, a firewall and a printer only.
4	Is 30 April 2027 the right renewal date for Client A?	Keep 30 April 2027.